



Initial Access in 2026

A silver tongue for the initial rung... of
network compromise

Suroosh

Principal Consultant at Rotas Security
with a specialty in initial access and
physical facility penetration tests



@pursuit_of_root



[linkedin.com/in/ariyan-suroosh-infosec/](https://www.linkedin.com/in/ariyan-suroosh-infosec/)



uy_scuti



Bailey

Unabashed Swifty. Was doing IT
when the world was new.



@mpbailey1911



[linkedin.com/in/mike-bailey-99199b5/](https://www.linkedin.com/in/mike-bailey-99199b5/)



mpbailey1911



What's Covered in this Talk?

90%

Red Team Vishing

TTPs, Infrastructure, Tips



10%

Defense/ Payloads

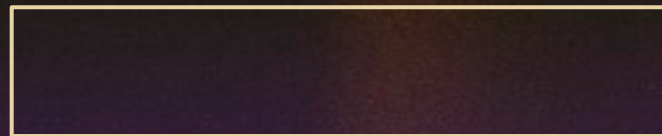
Defending against these tactics/
Payloads touched on briefly



0%

AI

Should be its own talk/ not super
necessary or applicable here





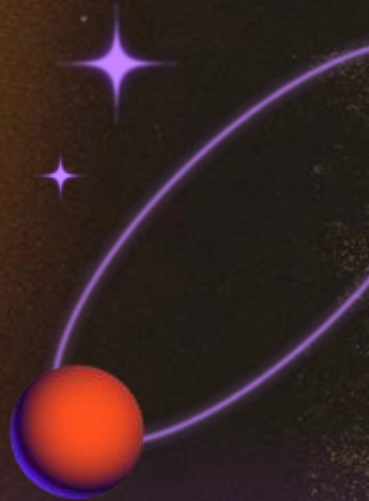
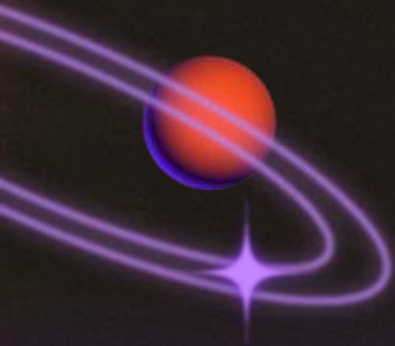
01

Red Team Vishing

How do those words go together?

Vishing

- Vishing (Voice Phishing) also sometimes called Phone Pretexting
- Often used on junior gigs to only attempt to gain information
- But can be so much more...

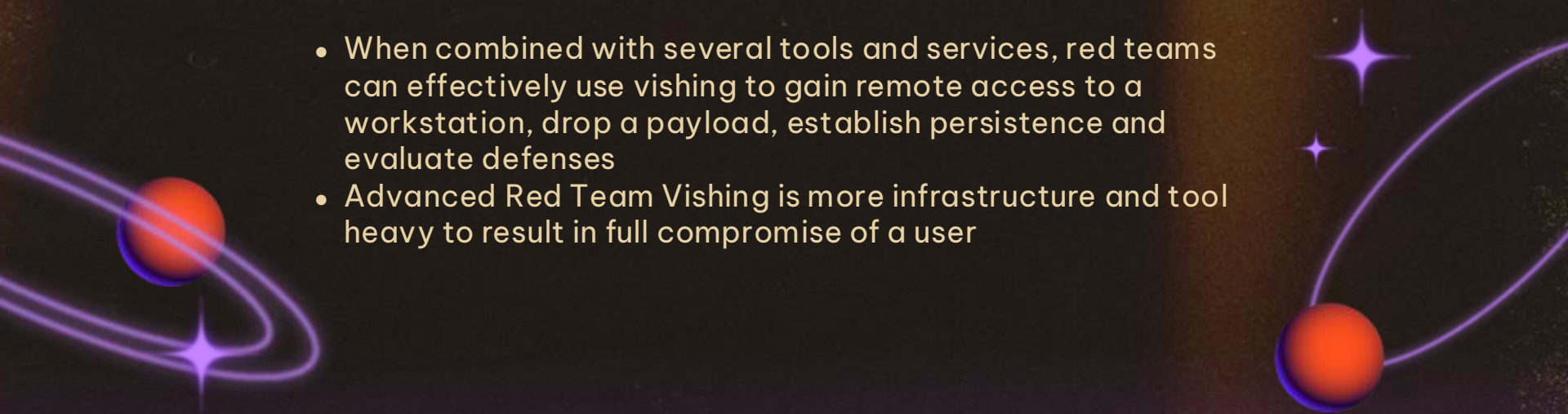


Initial Access is Hard

- Web Applications
 - Fewer custom sites with flaws
 - Less external footprint
- Spear phishing
 - Consistently filtered
 - Users more aware
- Physical facility device implant
 - Still viable but less realistic for international ATPs
- Teams
 - Rarely configured for external comms now
- SMS Phishing (Smishing)
 - Public very aware of scam texts
 - Not many convincing scenarios for texting
- Credential leak
 - Even with user credentials, MFA makes them far less useful
- Wireless
 - Seldom vulnerable in any super impactful way
- Simjacking
 - Not super realistic for consultant work

Advanced Red Team Vishing

- When combined with several tools and services, red teams can effectively use vishing to gain remote access to a workstation, drop a payload, establish persistence and evaluate defenses
- Advanced Red Team Vishing is more infrastructure and tool heavy to result in full compromise of a user



Real Impact

In an article published in July 2025, Unit 42 explains the dangers they were actively encountering

- “Between May 2024 and May 2025: **36%** of all incidents in the IR caseload began with a social engineering tactic.”
- “Threat actors such as Muddled Libra bypass multi-factor authentication (MFA) and exploit IT support processes to escalate privileges in minutes, often without malware. In one case, a threat actor moved from access to domain administrator in under 40 minutes using only built-in tools and social pretexts.”

The Key Enablers

- **Over-permissioned access**
- **Gaps in behavioral visibility**
- **Unverified user trust in human processes**

MGM and Caesars Casino Hacks

- In 2023, attackers called MGM's IT helpdesk, impersonating an employee.
- By tricking the helpdesk into resetting a password, they gained access to MGM's systems.
- Once inside, they moved laterally, escalating privileges and gaining control over critical infrastructure.

02



First Steps

Where to even begin?

Target Selection



**BARBARA
HILL**

Look for tenure



**MARTIN
SMITH**

Look for job title



**JENNIFER
DOE**

Look for location



**PETER
DAVIDS**

Look for phone
number
availability

Are they remote, in-office or hybrid?

Scenario Selection



Custom to Client

The best scenarios are specific and timely to the client, though not always possible



Not too Urgent

Things are rarely super urgent in workplaces, so be realistic

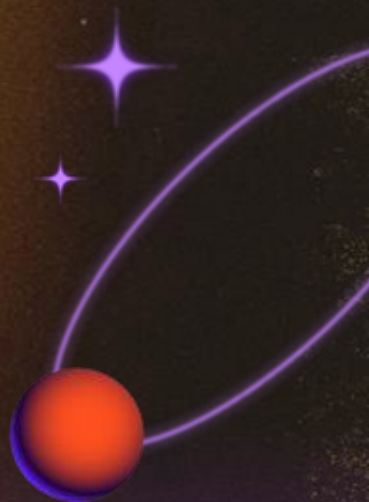
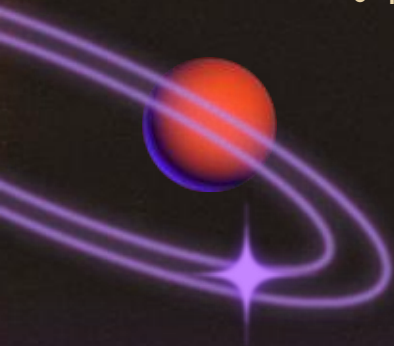


Grants Authority

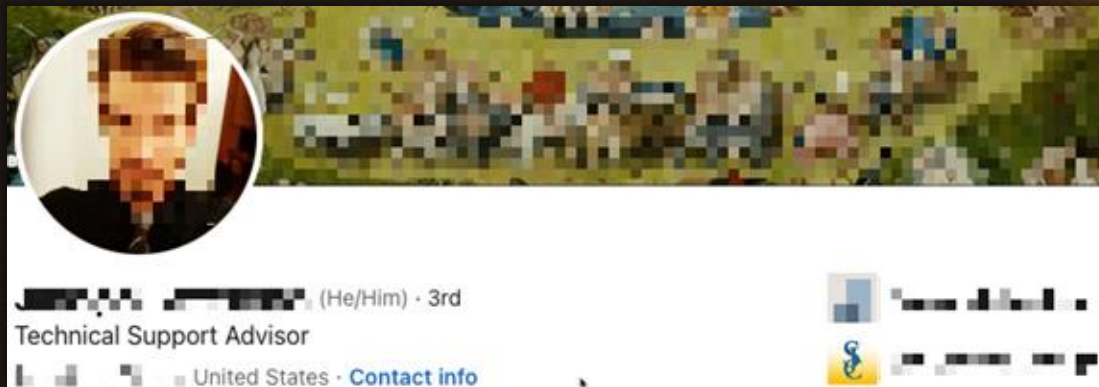
Needed to actually gain access or view information

Scripting

- Should be more of a framework than a script, you want to avoid reading
- Highlight a few key items:
 - Name of your target
 - Name of who you're impersonating
 - URL for Evilginx2
 - URL for S3 Bucket



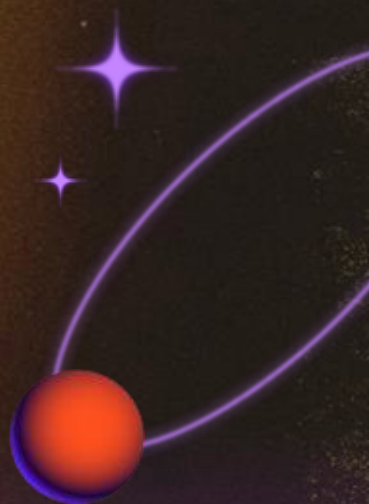
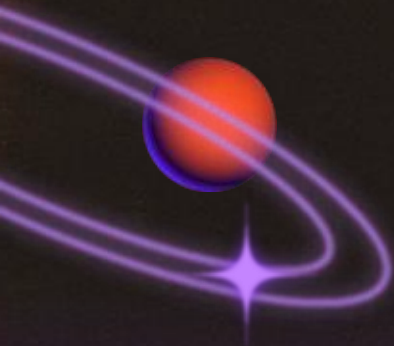
Target for Impersonation



- Looking for some of the same traits when identifying targets:
 - Tenure
 - Title
 - Location
 - Phone number
 - Remote, in-office or hybrid

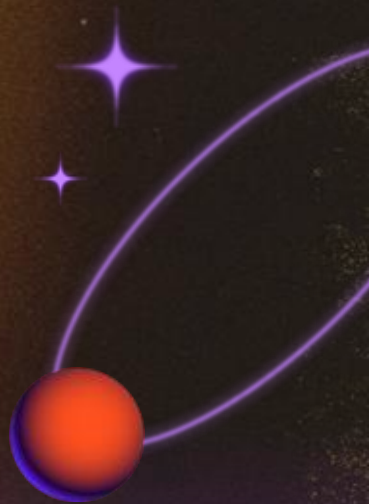
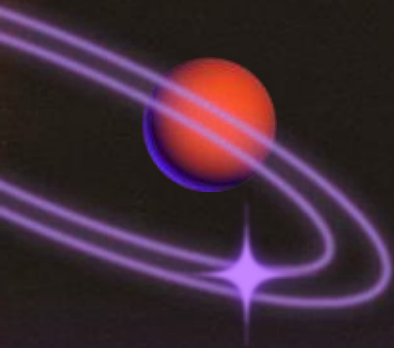
Finding Phone Numbers to target

- Can be tricky
- Don't spin wheels if you can't find a number within a few steps, just move on
- Tools
 - Seamless.ai/Apollo.io
 - Great for narrowing based on organization
 - BeenVerified.com
 - Great for finding multiple numbers
 - Zoominfo.com
 - Great but so expensive



Considering Phone Numbers to spoof

- Corporate number or local number?
- Appear as impersonation target or organization?
- Not always a choice, you may have to work with what you have



Making the calls successful

- Build in a question or statement that throws them off their “interaction ritual” right away i.e. “Do you remember denying an update last night or this morning?”
Example: Beer Samples
- Get relaxed
- Get in character
- Warm up
- You’ll usually know if the call will be successful after the few two or three exchanges
- Never give away the game. Things go sideways, just hang up
- Feel like you’re being toyed with? Just hang up

03

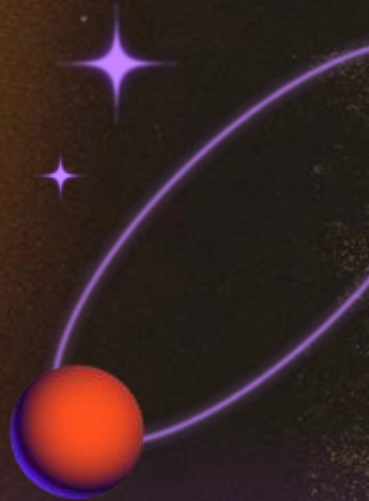
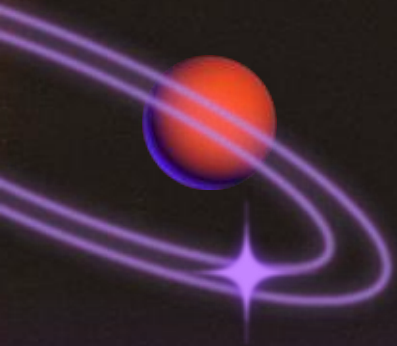


Infrastructure

Build up Believability

Infrastructure

- Setup highly legitimized infrastructure to fool the target and possibly bypass filters
- A little expensive, especially to keep running after the engagement
- Think of the following tools and platforms as categories. There are multiple tools that can provide each of these functions



Selecting your Domain

- One of the most important aspects
 - Your target will see the domain you choose and possibly type it in, keep it as short as possible
 - Fear not the hyphen
 - Prioritize the .com TLD, it will arouse the least suspicion
 - Do not buy old-school homographic/typosquatting style domains, too many defenses exist that will burn those out of the gate

Organization Domain Defenses



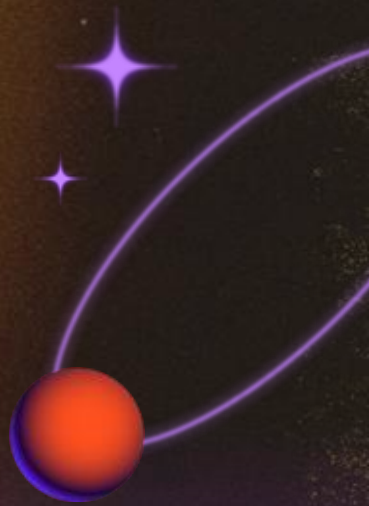
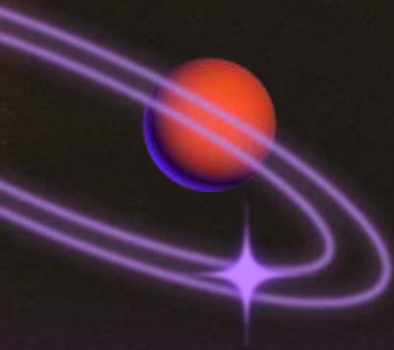
Domain OPSEC

- How do we bypass the many defenses?
 - Domain aging
 - Domain Categorization
 - Web traffic
 - Redirector



Using a CDN Instead

- A few pros
 - Reputation bypass
 - SSL Included and more trustworthy
 - Obfuscation
 - IP reputation
- A few cons
 - Detection by anomaly
 - Terms of service violation
 - URLs can be giveaways to targets



Microsoft 365 Business Licenses

Your organization

[Users](#) [Teams](#) [Products](#) [Upcoming changes \(5\)](#) [Learn](#) [Setup](#)

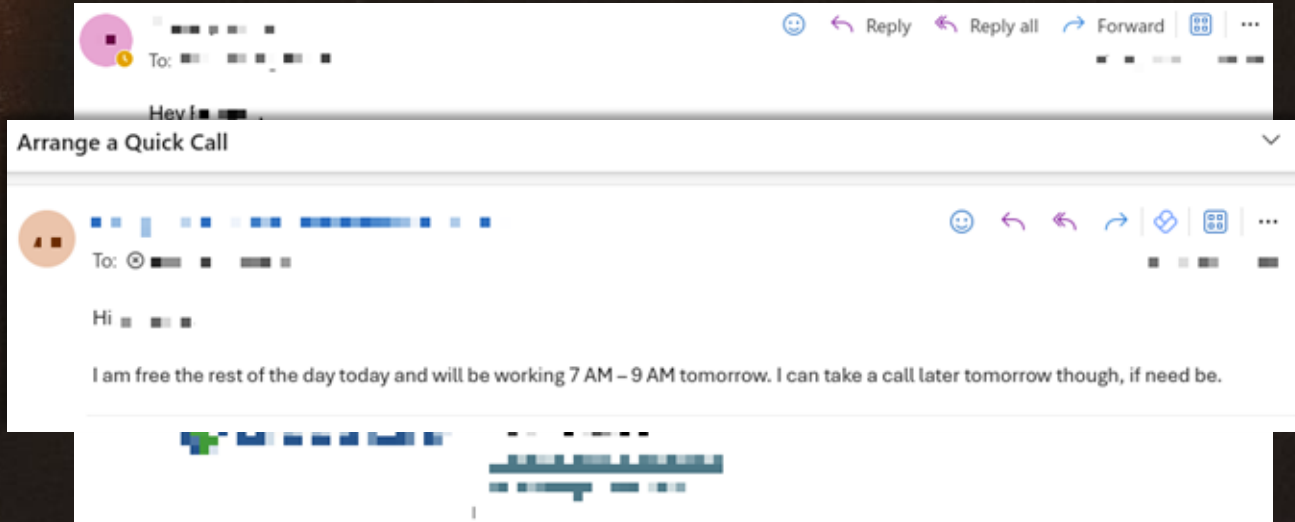
Manage who can access apps and services included in your Microsoft 365 subscriptions. Add or remove users, manage licenses, and reset passwords.

[+ Add user](#) [Reset password](#) [Assign phone numbers](#)

Name ↑	Username for sign-in	Licenses
AL		Unlicensed
A		Unlicensed
JL		Unlicensed
KL		Microsoft 365 Business Standard
KM		Microsoft Power Automate Free, Microsoft 365 Business Standard
R		Unlicensed
SA		Microsoft 365 Business Standard
WA		Unlicensed

- Allows for convincing source addresses for multiple tools that can follow the orgs schema
- Especially effective when combined with a clever domain (i.e. kyle.martin@help-desk.com)
- Big tip: setup an admin account and move around licenses as needed

Small Batch Spear Phishing



- Emails sent from a Microsoft business licensed email with an aged and categorized domain will often get through
- Can potentially send an email to arrange a call

Side note: Teams Enumeration and Messaging

```
"accountEnabled": true,  
"avatarUrl": "https://api.skype.com/users/live:a[REDACTED]_2/profile/avatar",  
"displayName": "[REDACTED]",  
"email": "[REDACTED]",  
"isShortProfile": false,  
"mri": "8:live:[REDACTED]",  
"type": "SkypeConsumer",  
userPrincipalName : "[REDACTED]"
```

- Once upon a time, it was far more common to find externally reachable employees
- TeamsUserEnum great for validation of users but also revealed legacy parameters which allowed for external comms against the orgs policy

04



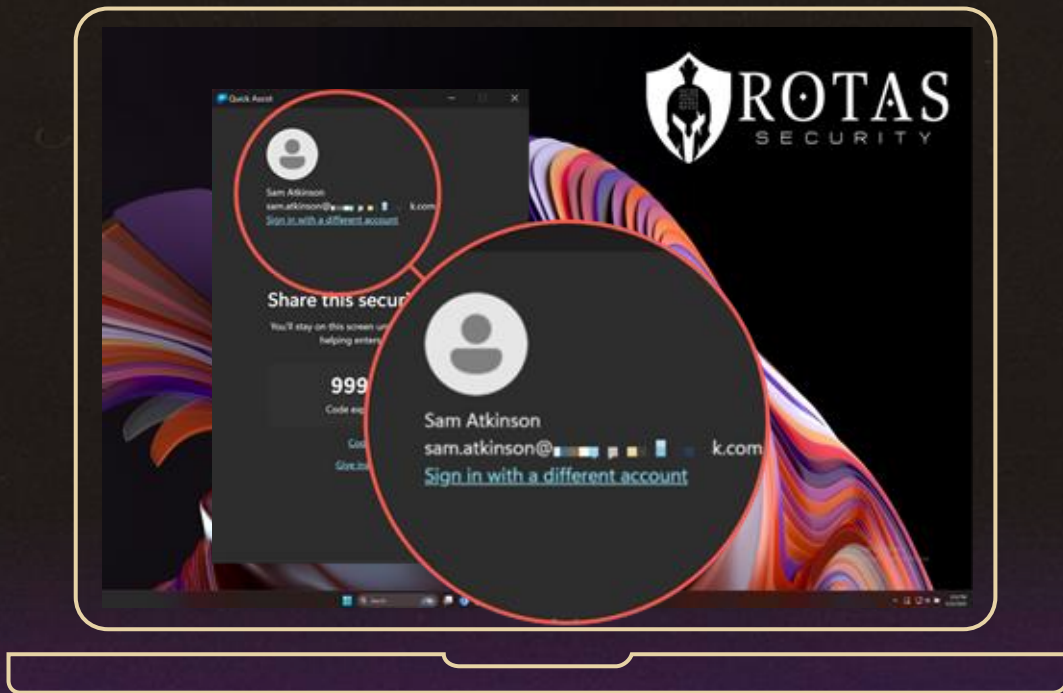
Tooling

A few ways to play this

Tools to Gain Remote Viewing and Control

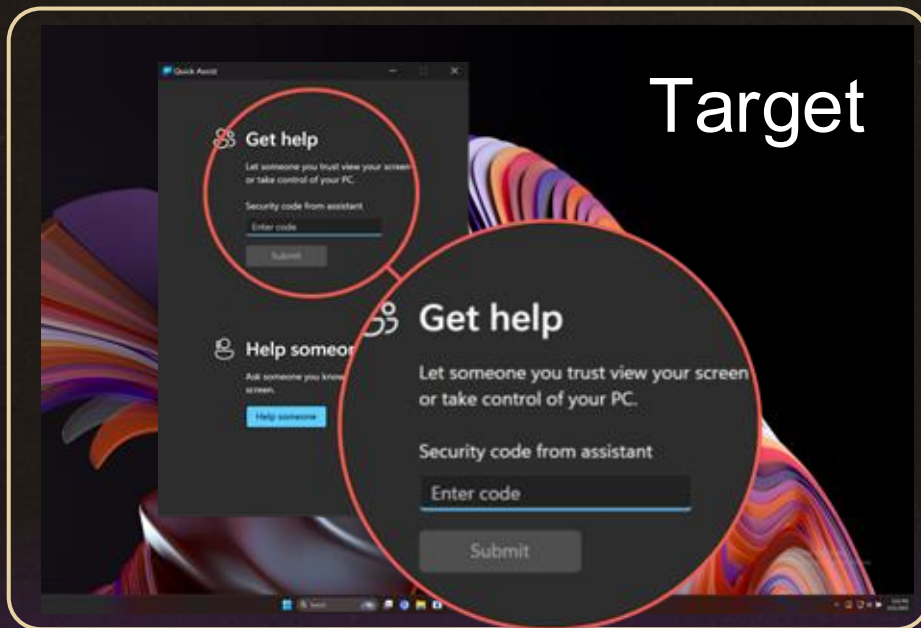


Remote Viewing and Control



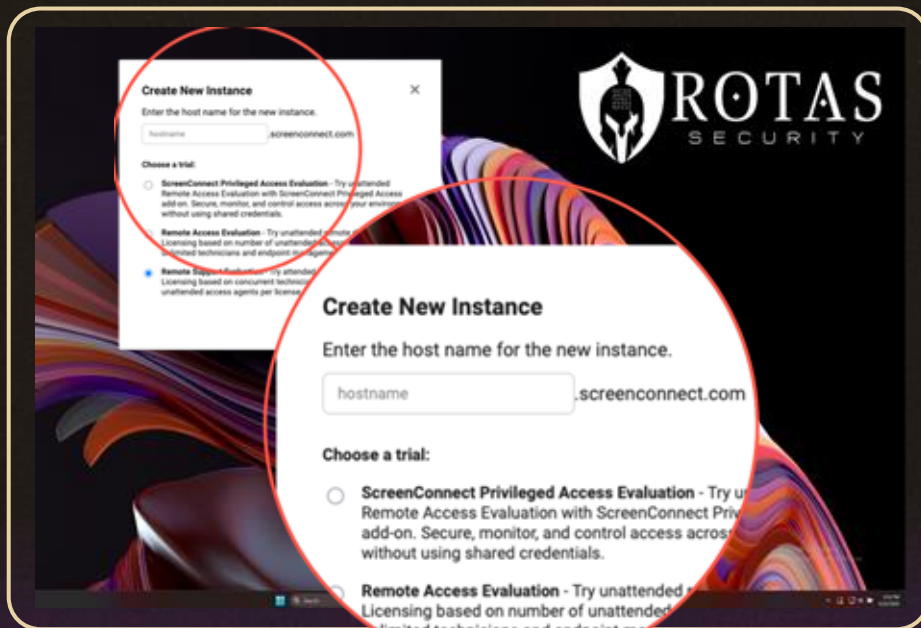
- Quick Assist is the most devastating though there are other options in a pinch
- Installed on Windows by default until May 2022 with Windows 11, version 22H2. Now located in Microsoft Store and disabled in many environments
- ScreenConnect and TeamViewer are options but require more steps and therefore more buyin

Remote Viewing and Control



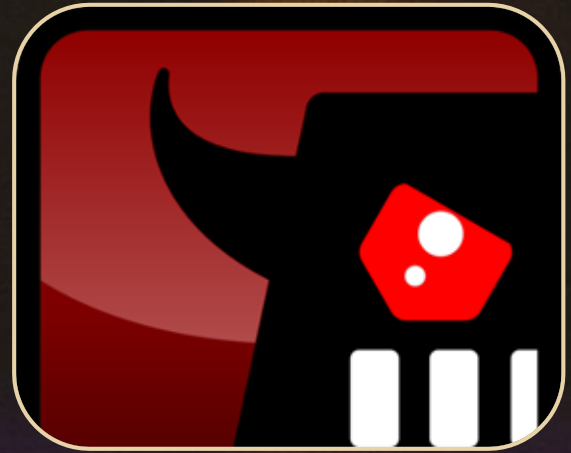
- Target only types in the short six-character code you provide them and then selects 'yes' to the prompt that follows to grant you control of their workstation
- From here, you can do a lot of things
 - Avoid suspicion by guiding the user to an Evilginx login portal, device code login page, etc to capture creds and cookies
 - Navigate to S3 bucket for payload
 - Navigate to HTML smuggle link?
 - Etc

Remote Viewing and Control



- ScreenConnect is not a terrible fallback
- Will have to provide the employee with the URL you create when setting up the instance
- Substantial drawback: Monitoring services will eventually flag and takedown an instance using a company name without proof of ownership, so move fast

Tools to Capture Credentials and Bypass MFA



Evilginx2

```
root@debian-evilginx:~/tools/evilginx2# ./build/evilginx -p ./phishlets/
```



Evilginx
no option - pure evil
by Kuba Gretzky (@gretzky) version 2.0.0

```
[00:23:56] [i] loaded phishlet 'google' from 'google.yaml'  
[00:23:56] [i] setting up certificates for phishlet 'google'...  
[00:23:56] [i] successfully set up 500/TLS certificates for domains: [accounts.it-is-almost-dow.evilginx.com apis.it-is-almost-dow.evilginx.com ssi.it-is-almost-dow.evilginx.com content.it-is-almost-dow.evilginx.com]  
[00:23:56] [i] [v] now visitor has arrived: Mozilla/5.0 (Windows NT 6.1; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/66.0.3359.126 Safari/537.36  
[00:23:56] [i] [v] landing URL: https://accounts.it-is-almost-dow.evilginx.com/signin/v2/identifier  
: sessions
```

id	phishlet	username	password	tokens	remote ip	time
19	google			none	85.25.224.104	2018-05-26 00:23

```
[00:24:22] [i] [v] Username: [to.who.you@well.com]  
[00:24:29] [i] [v] Password: [000000000000]  
[00:24:41] [i] [v] all authentication tokens interrupted!  
[00:24:41] [i] [v] redirecting to URL: https://redirect-to-this-url-after-logging-in.com  
: sessions
```

id	phishlet	username	password	tokens	remote ip	time
19	google	to.who.you@well.com	000000000000	captured	85.25.224.104	2018-05-26 00:24

- The go-to transparent proxy
- Allows for the capture of creds but more importantly, the bypassing of MFA via captured cookies
- Most effective when used alongside vishing, as you no longer depend on a link to make it through email
- Kuba Gretzky maintains the tool very well overall and is a great source for up-to-the-minute updates on phishing in general

Graphspy

```
(root@pvm-the5-kali) ~/opt/GraphSpy
# graphspy

<< 03:35:13 | 24.03.26 >>

by RedByte1337 v1.6.1

[*] First time use detected.
[*] Creating directory '/root/.gspy'.
[*] Creating directory '/root/.gspy/databases'.
[*] Database file '/root/.gspy/databases/database.db' not found. Initializing new database.
[*] Utilizing database '/root/.gspy/databases/database.db'.
[*] Starting GraphSpy. Open in your browser by going to the url displayed below.

  * Serving Flask app 'graphspy.cli'
  * Debug mode: off
WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
  * Running on http://127.0.0.1:5000
Press CTRL+C to quit
```

- My go-to for device code phishing. Just have to get user to go to the link and input the device code

EvilnoVNC

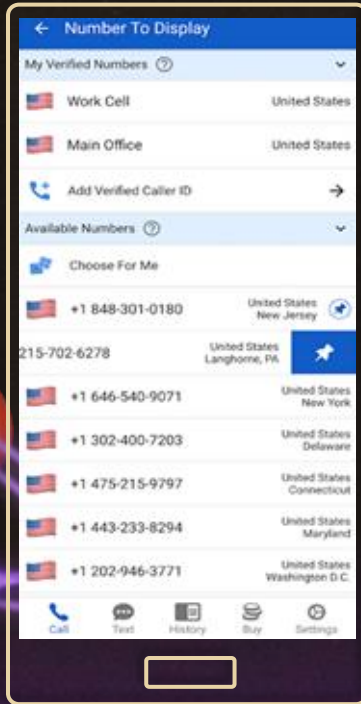


- Instead of a transparent proxy, the target is unknowingly controlling the attacker's browser
- The domain is largely the only giveaway, so make it good
- Also captures cookies

Tools to Make the Calls



Making the Calls



- Spoofcard
- Was the most common option, made this so simple
- Still allows you to call from a number that isn't your personal number, but you can't specify a number you want to anymore thanks to FCC regulations, more to come...

Burner Phone?



- Why not just buy a “burner” phone?
 - Same issue as SpoofCard
 - The key is the ability to choose a number that they will pick up i.e. Helpdesk, Headquarters

Solution: Personal Private Branch Exchange

- Buy a phone number from a wholesale SIP trunking provider like Skyetel, Twilio, Telnyx
- SIP trunking?
 - Session Initiation Protocol – protocol that sets up, manages, tears down the session over IP
 - Trunk – In olden times, a "trunk" was a physical bundle of phone lines connecting a business's PBX (private branch exchange) to the carrier's central office. Useful to picture in this way. SIP Trunk is the virtual equivalent.

Solution: Personal Private Branch Exchange

- SIP trunking is the underlying mechanism that makes flexible vishing infrastructure possible
 - With a SIP trunk and open-source PBX server like FreePBX, you can place calls with arbitrary caller ID values as long as neither services cares that you don't own the number you're providing

Solution: Personal Private Branch Exchange

- The core idea: caller ID is just a field you fill in
 - When you place a phone call over a SIP trunk, your PBX sends the provider a message that basically says "Please connect a call to 555-123-4567, and by the way, here's the caller ID to display: 555-999-0000."
 - Just like when you write a return address on an envelope, the post office doesn't do any validation of this address when you mail your letter

Doesn't work every time...

The TRACED Act

- US federal law passed in 2019, empowered FCC with expanded authority and tools to track, deter and penalize scam callers.
 - Telephone
 - Robocall
 - Abuse
 - Criminal
 - Enforcement and
 - Deterrence
 - Act

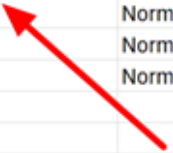
STIR/SHAKEN Framework

- STIR/SHAKEN is a framework of interconnected standards.
 - Secure
 - Telephone
 - Identity
 - Revisited (STIR)/
 - Signature-based
 - Handling of
 - Asserted Information Using to -
 - KENs (SHAKEN) standards

STIR/SHAKEN Framework

- When your provider hands off a call, they now cryptographically sign an attestation about the caller ID:
 - A (Full) – provider verified you own this number
 - B (Partial) – provider knows you but can't verify the number
 - C (Gateway) – provider has no idea, just passing it along
- The carrier on the receiving end sees the attestation level and increasingly marks B and C calls as "Spam Likely" or blocks them outright.

Inbound Tenant Name	Calling Area	Call Blocked	Shaken Attestation	Call Status	Spam Risk Score
	interstate	0 B		Normal	
	local	0 B		Normal	
	local	0 B		Normal	



Setup Summary



SIP Trunking Provider



PBX Service



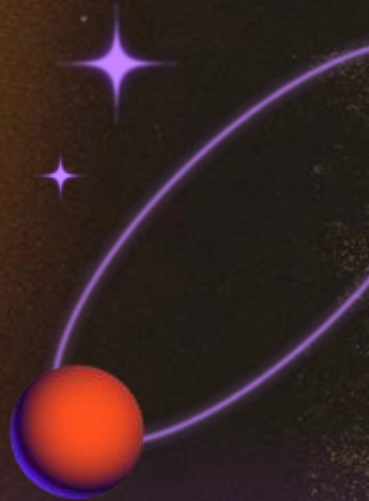
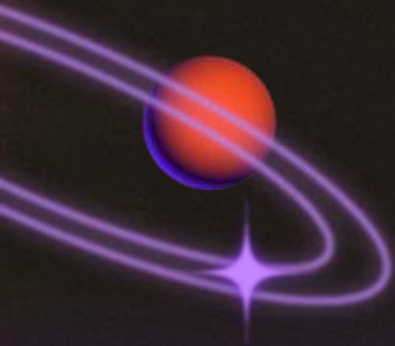
VoIP Application

Payloads



Payloads

- The target is often staring at their screen while you operate so payloads have to play to the scenario at least a little
- Operational considerations to maintain the rouse:
 - Script jacked programs
 - Sideloaded programs
 - MSI files
- Standard encrypted payloads are an option, so long as they are explainable to the target



MSI Download

- MSI files are great
- Can encrypt file and discuss entering credentials as part of the scenario
- If you trigger an alert, explain it away.
“We came up with kind of a hacky script to get you re-enrolled and the workstations do not like it haha”
- S3 buckets

Defense

Security awareness training is part of it yes, but...

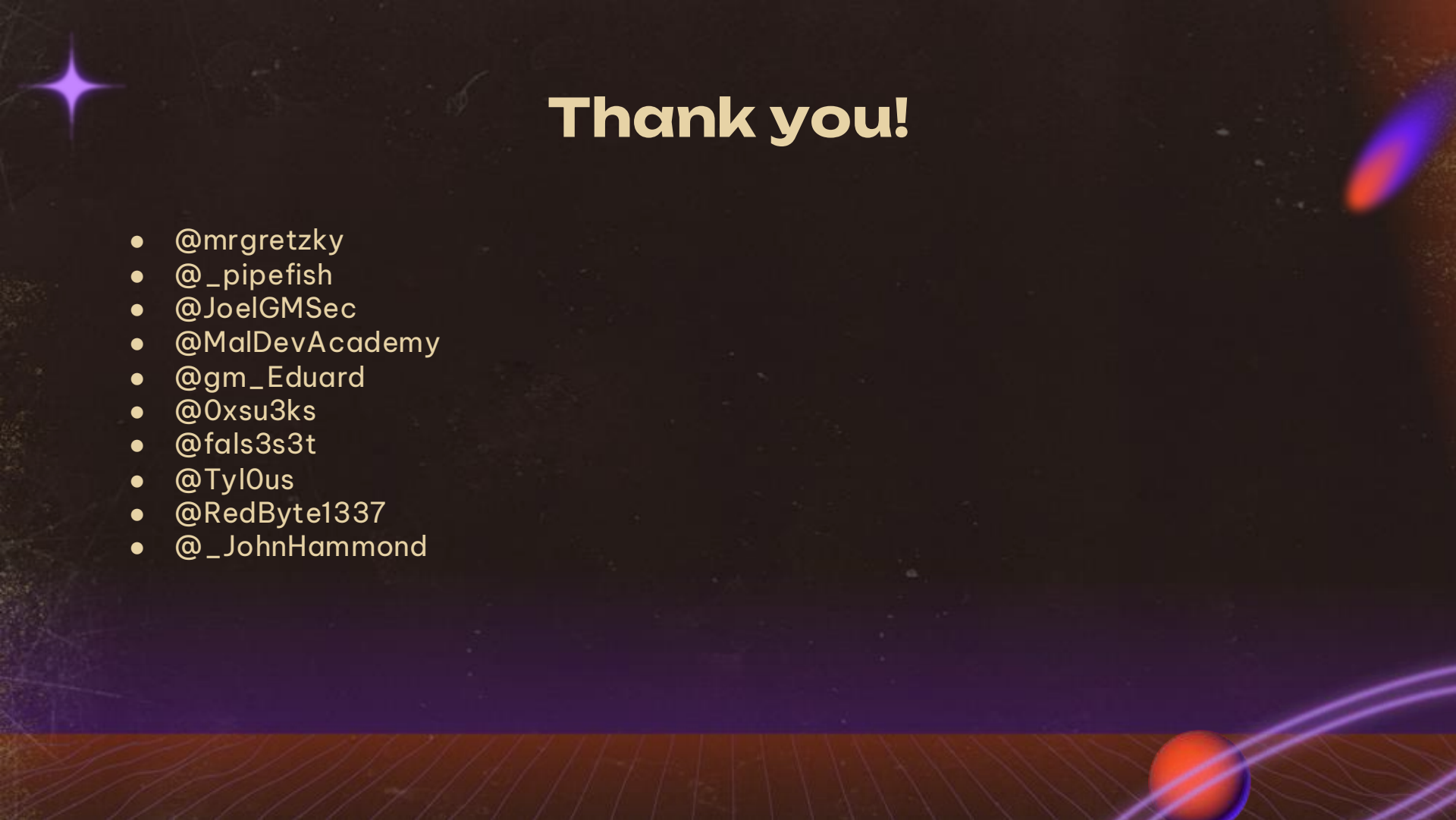
- Behavioral analytics
- Identity Threat Detection and Response (ITDR)
- Enforce conditional access
- Expanding Zero Trust principles to encompass users

The background is a dark, textured space scene. In the upper left, a red planet with a blue shadow is shown with a glowing purple elliptical orbit. In the upper right, a comet with a blue and red tail streaks across the sky. In the lower right, another red planet with a blue shadow is shown with a glowing purple elliptical orbit. Two bright, four-pointed stars are visible on the left side. The bottom of the image features a series of thin, wavy, light-colored lines on a dark background, suggesting a horizon or a textured surface.

Questions?

Works Cited

- <https://github.com/kgretzky/evilginx2>
- <https://www.microsoft.com/en-us/security/blog/2024/05/15/threat-actors-misusing-quick-assist-in-social-engineering-attacks-leading-to-ransomware/>
- <https://dmarcly.com/blog/what-is-bimi-bimi-explained>
- <https://maldevacademy.com/>
- <https://www.fcc.gov/call-authentication>
- <https://github.com/RedByte1337/GraphSpy>
- <https://web.stanford.edu/~eckert/PDF/GoffmanFace1967.pdf>
- <https://www.youtube.com/watch?v=qEtoKC32UoE>
- <https://rift.stacktitian.com/cid-spoofing/>
- <https://unit42.paloaltonetworks.com/2025-unit-42-global-incident-response-report-social-engineering-edition/>



Thank you!

- @mrgretzky
- @_pipefish
- @JoelGMSec
- @MalDevAcademy
- @gm_Eduard
- @0xsu3ks
- @fals3s3t
- @Tyl0us
- @RedByte1337
- @_JohnHammond